BIA

Analiza wpływu na działalność



Business Impact Analysis – od wymagań ustawy o KSC i normy ISO 22301 do klas krytyczności procesów

Materiał wprowadzający do zajęć laboratoryjnych

Plan zajęć

01	**Dlaczego BIA?**	Wymagania ustawy o KSC (NIS2) dotyczące ciągłości działania
02	**Co mówi ISO 22301**	Kontekst organizacji, nadzór operacyjny, BIA i ocena ryzyka
03	**Podstawowe pojęcia**	MTPD, RTO, RPO, MBCO, ryzyko
04	**Przebieg BIA**	Kryteria, ocena wpływu w czasie, klasy krytyczności
05	**Laboratorium**	Przeprowadzenie BIA dla studium przypadku

Po co nam BIA – cel zajęć

BIA odpowiada na trzy pytania

Co? Które procesy i usługi są dla organizacji naprawdę istotne

Jak szybko? W jakim czasie muszą zostać przywrócone (RTO, MTPD)

Czym? Jakich zasobów, danych i dostawców do tego potrzebujemy

Po laboratorium potrafisz:

- wskazać podstawę prawną i normatywną BIA
- posługiwać się pojęciami MTPD, RTO, RPO, MBCO
- zbudować kryteria i skalę oceny wpływu
- ocenić wpływ przerwy w przedziałach czasowych
- przypisać procesom klasy krytyczności
- zidentyfikować zasoby i zależności od dostawców

CZĘŚĆ 1



Dlaczego BIA? Wymagania prawne

Ustawa o krajowym systemie cyberbezpieczeństwa (wdrożenie dyrektywy NIS2)

Od dyrektywy NIS2 do ustawy o KSC



Dyrektywa NIS2

(UE) 2022/2555
art. 21 – środki zarządzania ryzykiem, w tym ciągłość działania i odtwarzanie po awarii



Ustawa o KSC

Nowelizacja wdrażająca NIS2: podmioty kluczowe i podmioty ważne



SZBI

Obowiązek wdrożenia systemu zarządzania bezpieczeństwem informacji



Ciągłość działania

Plany ciągłości, plany awaryjne i plany odtworzenia

Ciągłość działania jest jednym z obowiązkowych środków zarządzania ryzykiem – nie opcją.

Obowiązek SZBI dla podmiotu kluczowego i ważnego

Podmiot kluczowy lub podmiot ważny wdraża SZBI w systemie informacyjnym wykorzystywanym w procesach wpływających na świadczenie usługi, zapewniający m.in.:



1) Systematyczne szacowanie ryzyka wystąpienia incydentu i zarządzanie tym ryzykiem



2) Odpowiednie i proporcjonalne środki techniczne i organizacyjne – uwzględniające stan wiedzy, koszty, wielkość podmiotu, prawdopodobieństwo incydentów i ich skutki społeczne i gospodarcze



2e) Bezpieczeństwo i ciągłość łańcucha dostaw produktów, usług i procesów ICT



2f) **Plany ciągłości działania, plany awaryjne i plany odtworzenia działalności**



2g) Objęcie systemu informacyjnego systemem monitorowania w trybie ciągłym

Co dokładnie wymaga pkt 2f?



Wdrażanie, dokumentowanie, testowanie i utrzymywanie

Cały cykl życia planów – nie jednorazowy dokument



Plany ciągłości działania

Ciągłe i niezakłócone świadczenie usługi z zachowaniem poufności, integralności, dostępności i autentyczności informacji



Plany awaryjne

Działanie w trybie zastępczym w czasie zakłócenia



Plany odtworzenia

Odtworzenie systemu informacyjnego po zdarzeniu, które spowodowało straty przekraczające zdolność podmiotu do odbudowy własnymi środkami

Bez BIA nie wiadomo, które usługi planować, w jakiej kolejności i na jakim minimalnym poziomie.

Łańcuch dostaw i dokumentacja

Łańcuch dostaw ICT (pkt 2e)

- Bezpieczeństwo i ciągłość produktów, usług i procesów ICT, od których zależy świadczenie usługi
- Uwzględnienie relacji z bezpośrednim dostawcą sprzętu lub oprogramowania
- W BIA: każdy proces krytyczny musi mieć zidentyfikowanych dostawców i ich zdolność do odtworzenia

Dokumentacja normatywna

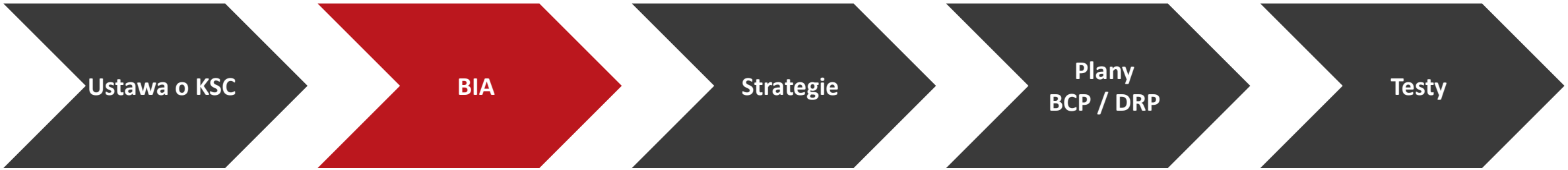
Do dokumentacji bezpieczeństwa systemu informacyjnego zalicza się m.in.:

Dokumentacja systemu zarządzania bezpieczeństwem informacji

Dokumentacja ochrony infrastruktury, z wykorzystaniem której świadczona jest usługa

Dokumentacja systemu zarządzania ciągłością działania

Wniosek: BIA to fundament ciągłości działania



wymaga planów ciągłości proporcjonalnych do ryzyka i skutków

określa skutki przerwy w czasie i priorytety

dobór rozwiązań spełniających RTO / RPO

procedury, role, tryby zastępcze

weryfikacja, że parametry są osiągalne

Bez rzetelnej BIA plany ciągłości są albo przewymiarowane (koszty), albo niedoszacowane (nieakceptowalne skutki).

CZĘŚĆ 2



Co mówi norma ISO 22301

System zarządzania ciągłością działania (BCMS) – od kontekstu organizacji do analizy wpływu

Rodzina norm ciągłości działania

ISO 22301

Wymagania dla BCMS – podstawa certyfikacji

ISO 22300

Terminologia: MTPD, RTO, RPO, MBCO

ISO 22313

Wytyczne stosowania ISO 22301

ISO/TS 22317

Wytyczne prowadzenia analizy BIA

ISO/IEC 27031

Gotowość ICT na potrzeby ciągłości działania

ISO 31000

Zarządzanie ryzykiem – zasady i wytyczne

Struktura ISO 22301 w cyklu PDCA

PLAN	DO	CHECK	ACT
4 Kontekst organizacji 5 Przywództwo 6 Planowanie 7 Wsparcie	8 Działania operacyjne 8.2 BIA i ocena ryzyka 8.3 Strategie 8.4 Plany i procedury 8.5 Ćwiczenia	9 Ocena efektów działania audyt wewnętrzny przegląd zarządzania	10 Doskonalenie niezgodności działania korygujące

Dzisiaj skupiamy się na: 4.1, 4.2, 8.1 oraz 8.2

4.1 Zrozumienie organizacji i jej kontekstu

Wymaganie normy

Organizacja powinna określić czynniki zewnętrzne i wewnętrzne istotne dla celu jej działania, które wpływają na zdolność osiągnięcia zamierzonych wyników BCMS.

UWAGA: czynniki te mają wpływ na cele organizacji, jej wyroby i usługi oraz wielkość i rodzaj ryzyka, jakie organizacja może podjąć albo nie podejmować.



Czynniki zewnętrzne

- regulacje (KSC, RODO, DORA)
- klienci i rynek
- dostawcy i chmura
- krajobraz zagrożeń



Czynniki wewnętrzne

- misja i cele
- struktura i kultura
- architektura IT
- zasoby i kompetencje

4.2 Potrzeby stron zainteresowanych i wymagania prawne

4.2.1 Organizacja powinna określić:

a) strony zainteresowane istotne dla BCMS

b) istotne wymagania tych stron

Przykłady: klienci, regulator (organ właściwy, CSIRT), właściciele, pracownicy, dostawcy, ubezpieczyciel.

4.2.2 Wymagania prawne i regulacyjne

a) wdrożyć i utrzymywać proces identyfikacji wymagań prawnych i regulacyjnych dotyczących ciągłości wyrobów, usług, działań i zasobów

b) zapewnić, że wymagania są uwzględniane we wdrażaniu i utrzymywaniu BCMS

c) dokumentować te informacje i je aktualizować

8.1 Planowanie i nadzór nad działaniami operacyjnymi

Organizacja planuje, wdraża i nadzoruje procesy potrzebne do spełnienia wymagań poprzez:

a)

ustanowienie kryteriów dla procesów

b)

nadzór nad procesami zgodnie z kryteriami

c)

przechowywanie udokumentowanych informacji potwierdzających realizację

Zmiany

Nadzór nad planowanymi zmianami i przegląd następstw zmian niezamierzonych

Outsourcing i łańcuch dostaw

Procesy zlecone na zewnątrz oraz łańcuch dostaw muszą być nadzorowane

8.2.1 Analiza wpływu i ocena ryzyka – postanowienia ogólne

a) Systematyczne procesy

Wdrażać i utrzymywać systematyczne procesy analizy wpływu biznesowego i oceny ryzyka wystąpienia zakłóceń.

b) Przeglądy

Przeglądać BIA i ocenę ryzyka w planowanych odstępach czasu oraz przy istotnych zmianach w organizacji lub jej kontekście.

UWAGA: organizacja sama określa kolejność BIA i oceny ryzyka

BIA

Co jest krytyczne i jak szybko musi wrócić?

Ocena ryzyka

Co może zakłócić procesy krytyczne i jak prawdopodobne?

Strategie (8.3)

Jak ograniczyć ryzyko i spełnić RTO/RPO?

8.2.2 Analiza wpływu biznesowego – osiem kroków

a

Określić rodzaje wpływu i kryteria oddziaływania istotne dla kontekstu

b

Zidentyfikować działania wspierające dostarczanie wyrobów i usług

c

Oceniać wpływy w czasie wynikające z zakłócenia tych działań

d

Wyznaczyć ramy czasowe, po których brak wznowienia staje się nieakceptowalny → MTPD

e

Ustalić priorytetowe ramy czasowe wznowienia przy minimalnej zdolności → RTO

f

Wykorzystać analizę do identyfikacji działań priorytetowych

g

Określić zasoby potrzebne do wsparcia działań priorytetowych

h

Określić zależności, w tym partnerów i dostawców, oraz współzależności

CZĘŚĆ 3



Podstawowe pojęcia

MTPD, RTO, RPO, MBCO i ryzyko – na podstawie PN-EN ISO 22300

Czym jest BIA

Business Impact Analysis

Analiza wpływu biznesowego

Proces analizowania wpływu na organizację w czasie zakłócenia.

Analizujemy skutek przerwania ciągłości działania w określonych przedziałach czasowych.



BIA pyta o skutki

Co się stanie, jeśli proces nie działa przez 1 h, 4 h, 1 dzień, tydzień?



Nie o przyczyny

Przyczyny zakłóceń (pożar, ransomware, awaria dostawcy) analizuje ocena ryzyka



Wynik

Priorytety, parametry czasowe, wymagane zasoby i zależności

Kategorie wpływu



Bezpieczeństwo

życie lub zdrowie ludzi



Cele

realizacja celów strategicznych i operacyjnych



Wymagania prawne

w tym zapewnienie świadczenia usługi



Wymagania umowne

SLA, kary umowne, zobowiązania



Zaufanie

reputacja, wizerunek, relacje z klientami



Jakość

poziom świadczonych usług i produktów



Finanse

utracone przychody, koszty, kary

Maksymalny tolerowany okres zakłócenia – MTPD



MTPD

Maximum Tolerable Period of Disruption

Definicja

Czas, po którym niekorzystne skutki powstałe w wyniku niedostarczenia wyrobu lub usług lub nierealizowania działalności stają się nieakceptowalne.

W praktyce

- Wynika z oceny wpływu w czasie (ISO 22301 8.2.2 d)
- Wyznacza go właściciel procesu i kierownictwo – nie dział IT
- Granica, po której organizacja może nie przetrwać lub złamać prawo

Na podstawie PN-EN ISO 22300

Czas wznowienia działania – RTO



Definicja

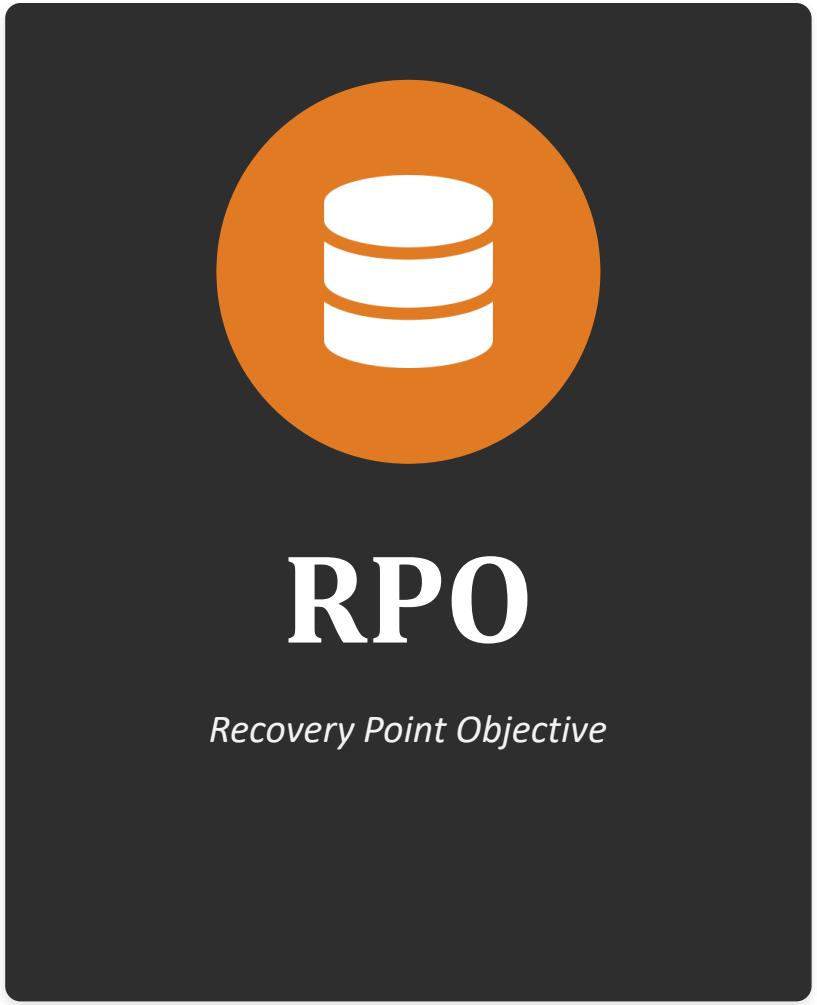
Priorytetowy przedział czasowy w ramach MTPD na wznowienie zakłóconych działań na minimalnym, akceptowalnym, zdefiniowanym poziomie.

W tym czasie

- wyrób lub usługa musi zostać ponownie dostarczana, lub
- działalność musi zostać wznowiona, lub
- zasoby muszą zostać odtworzone
- **Zawsze: RTO < MTPD**

Na podstawie PN-EN ISO 22300

Docelowy punkt odtworzenia danych – RPO



Definicja

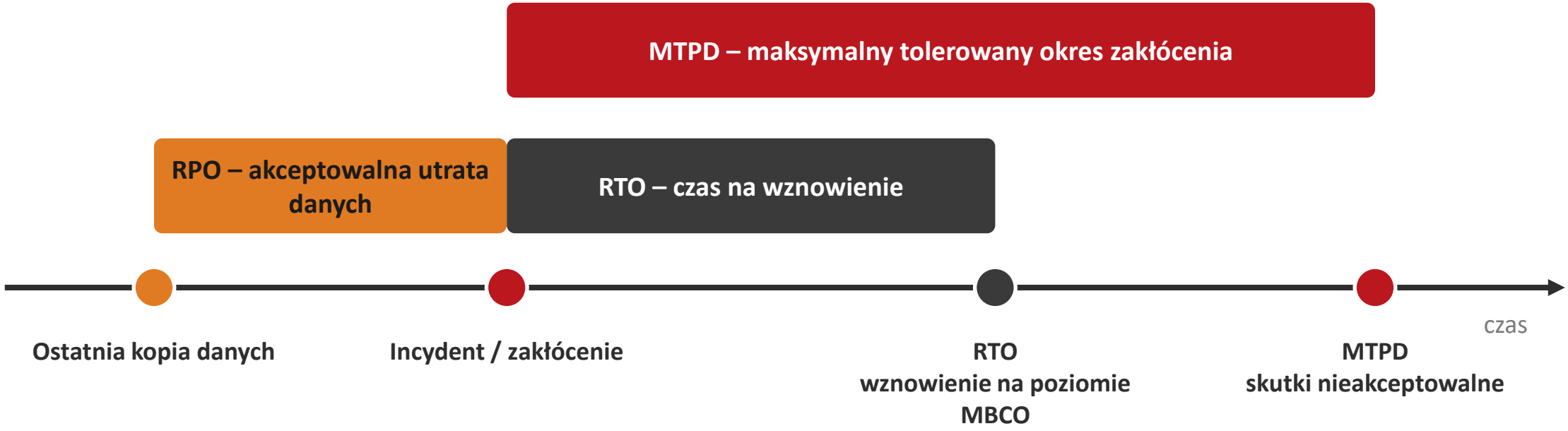
Punkt w czasie, do którego przywracane są informacje i dane wykorzystywane w ramach danej działalności, aby umożliwić tej działalności wznowienie funkcjonowania.

Konsekwencje

- Określa akceptowalną utratę danych – mierzoną wstecz od incydentu
- Wyznacza częstotliwość kopii zapasowych i replikacji
- RPO = 15 min oznacza, że kopia nie może być starsza niż 15 min

Na podstawie PN-EN ISO 22300

Jak MTPD, RTO i RPO układają się na osi czasu



Reguła: RTO < MTPD. RPO liczymy wstecz od incydentu, RTO i MTPD – do przodu. Między RTO a MTPD działamy na poziomie MBCO.

MBCO – minimalny akceptowalny poziom

MBCO (Minimum Business Continuity Objective) – minimalny poziom produktów lub usług, który jest akceptowalny dla organizacji po zakłóceniu.



Parametry ilościowe

np. 60% wolumenu transakcji



Parametry jakościowe

np. bez funkcji raportowych



Sposób realizacji

np. tryb ręczny, papierowy



Czas reakcji i obsługi

np. odpowiedź w 4 h zamiast 1 h

Akceptowalne odstępstwa od wymagań: „lepiej mniej niż wcale”, „mniejsze zło”, priorytet wartości i rezultatów (ograniczenia skutków) nad wymaganiem.

Ryzyko – dwie perspektywy



Ryzyko (IIA)

Pozytywny lub negatywny wpływ niepewności na cele.

Znaczenie ryzyk mierzy się zazwyczaj poprzez ocenę wpływu i prawdopodobieństwa.

The Institute of Internal Auditors



Ryzyko (bezpieczeństwo informacji)

Wpływ niepewności na cele.

Ryzyko często wyraża się jako kombinację następstw zdarzenia i związanego z nim prawdopodobieństwa jego wystąpienia.

PN-ISO 31000:2018 / PN-EN ISO 22301:2020

RYZYKO = SKUTEK × PRAWDOPODOBIEŃSTWO

BIA a ocena ryzyka – porównanie

	BIA	Ocena ryzyka
Pytanie	Co się stanie, gdy proces stanie?	Co może spowodować zakłócenie?
Przedmiot	Procesy, usługi, działania	Zagrożenia, podatności, zasoby
Założenie	Zakłócenie już wystąpiło	Zakłócenie może wystąpić
Miara	Skutek narastający w czasie	Skutek × prawdopodobieństwo
Wynik	Priorytety, MTPD, RTO, RPO, MBCO, zasoby	Ryzyka do postępowania, środki zabezpieczeń
Odbiorca	Strategie i plany ciągłości	Plan postępowania z ryzykiem

CZĘŚĆ 4



Jak przeprowadzić BIA

Od kryteriów oceny do klas krytyczności procesów i systemów

Etapy przeprowadzenia BIA



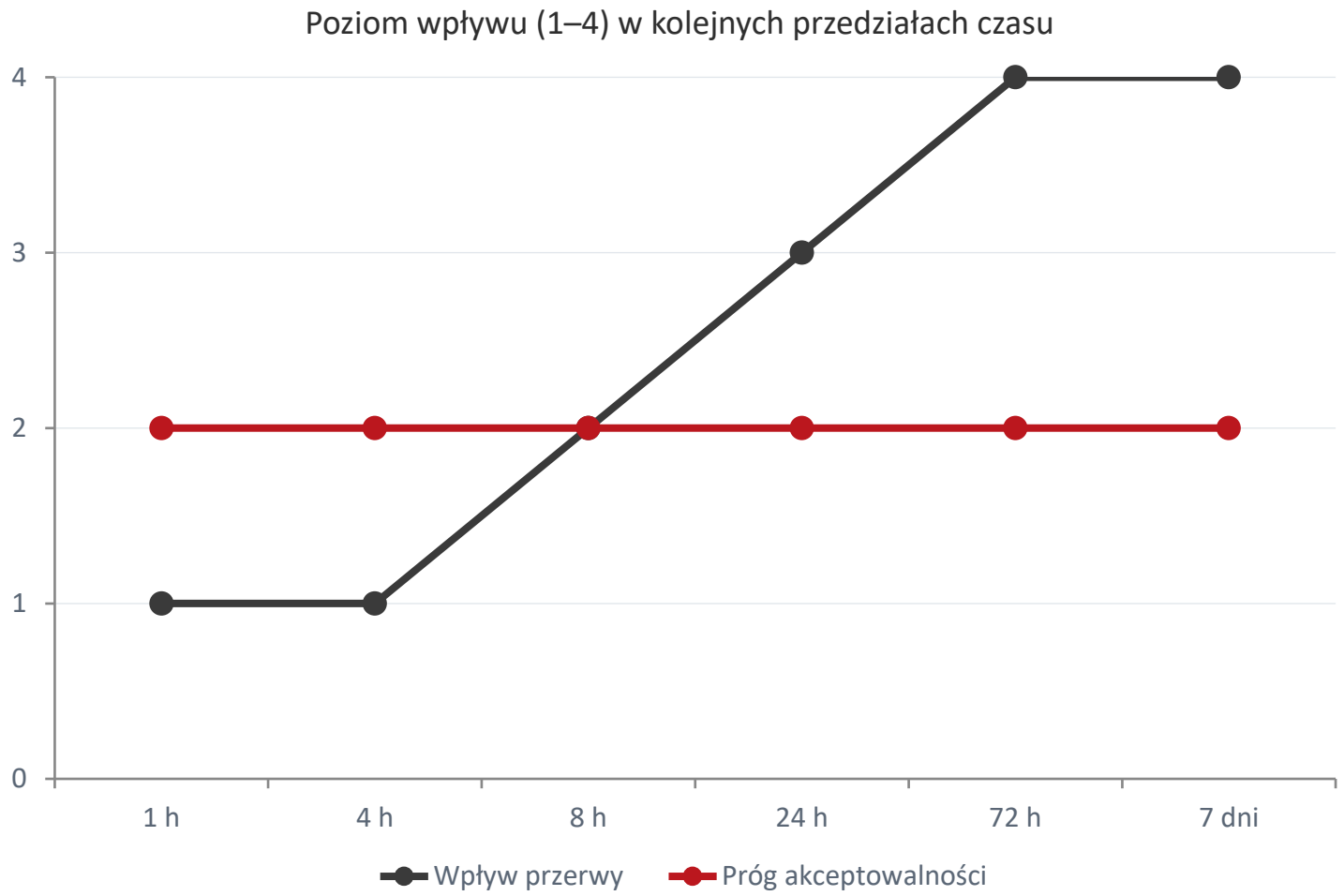
1	2	3	4	5	6	7
Zakres i kryteria	**Inwentaryzacja procesów**	**Zbieranie danych**	**Ocena wpływu w czasie**	**Parametry**	**Zasoby i zależności**	**Walidacja i zatwierdzenie**
usługi w zakresie, kategorie i skala wpływu, przedziały czasu	procesy, usługi, właściciele	kwestionariusze, wywiady, warsztaty	dla każdej kategorii i przedziału	MTPD, RTO, RPO, MBCO, klasa	ludzie, IT, dane, lokalizacje, dostawcy	uzgodnienie, akceptacja kierownictwa

Krok 1: skala oceny wpływu

Kategoria	1 – Niski	2 – Średni	3 – Wysoki	4 – Krytyczny
Bezpieczeństwo ludzi	brak zagrożenia	niewielkie, odwracalne	poważne zagrożenie zdrowia	zagrożenie życia
Wymagania prawne	brak naruszenia	drobne uchybienie	naruszenie, zgłoszenie do organu	sankcje, utrata uprawnień
Wymagania umowne	w granicach SLA	przekroczenie SLA	kary umowne	zerwanie umowy
Zaufanie	brak rozgłosu	skargi klientów	media lokalne	media ogólnokrajowe, odejście klientów
Finanse	< 0,1% przychodu	0,1–1%	1–5%	> 5% przychodu
Usługa / jakość	niezauważalny spadek	ograniczenie funkcji	poważne ograniczenie	brak świadczenia usługi

Skutek procesu w danym przedziale czasu = najwyższa ocena spośród kategorii.

Krok 2: ocena wpływu w czasie i wyznaczenie MTPD



Próg przekroczony

między 8 h a 24 h

MTPD

24 h

RTO (z zapasem)

8 h

Klasa

K2 – Wysoka

Klasy krytyczności procesów

K1 Krytyczna	Przerwanie bezpośrednio zagraża bezpieczeństwu ludzi lub uniemożliwia świadczenie usługi kluczowej	**RTO ≤ 4 h** RPO ≤ 15 min
K2 Wysoka	Procesy istotne dla realizacji usługi; krótka przerwa akceptowalna przy trybie zastępczym	**RTO ≤ 8 h** RPO ≤ 1 h
K3 Średnia	Procesy administracyjne i rozliczeniowe; przerwa do doby możliwa do obsłużenia	**RTO ≤ 24 h** RPO ≤ 4 h
K4 Niska	Procesy pomocnicze; przerwa kilkudniowa nie wpływa na świadczenie usługi	**RTO ≤ 72 h** RPO ≤ 24 h

Wartości orientacyjne – każda organizacja kalibruje je do własnego kontekstu i MTPD.

Przykład: procesy i systemy krytyczne

Proces / system	Klasa	RTO	RPO	Tryb zastępczy
Platforma świadczenia usługi (system transakcyjny)	**K1**	≤ 4 h	≤ 15 min	Przełączenie na ośrodek zapasowy, komunikat dla klientów
Uwierzytelnianie i zarządzanie tożsamością	**K1**	≤ 4 h	≤ 15 min	Konta awaryjne, procedura ręcznego nadawania dostępu
Monitorowanie bezpieczeństwa (SOC / SIEM)	**K2**	≤ 8 h	≤ 1 h	Monitoring lokalny, ręczna analiza logów
Obsługa klienta i zgłoszeń	**K2**	≤ 8 h	≤ 1 h	Infolinia, rejestr zastępczy
Integracje z partnerami (usługi zewnętrzne)	**K2**	≤ 8 h	n/d (usługa zewn.)	Kolejkowanie komunikatów, tryb offline
Finanse, księgowość, płace	**K3**	≤ 24 h	≤ 4 h	Praca odroczona, bufory danych
Poczta, intranet, systemy biurowe	**K3/K4**	≤ 24–72 h	≤ 4–24 h	Komunikacja telefoniczna / alternatywna

Zasoby i zależności (8.2.2 g–h)

Ludzie

kluczowe kompetencje, zastępstwa

Systemy i infrastruktura IT

aplikacje, sieć, centrum danych, chmura

Informacje i dane

kopie zapasowe, dokumentacja

Lokalizacje

budynki, miejsca pracy zastępczej

Dostawcy i partnerzy

usługi ICT, umowy, SLA

Współzależności

procesy zasilające inne procesy

Zasada dziedziczenia

- Zasób wspierający proces K1 musi spełnić parametry K1
- RTO zasobu ≤ RTO procesu, RPO zasobu ≤ RPO procesu
- Zależność od dostawcy → wymagania w umowie (SLA, RTO, testy)
- Pojedynczy punkt awarii (SPOF) to sygnał do strategii

Najczęstsze błędy w BIA

BIA systemów zamiast procesów

Najpierw procesy i usługi, systemy dopiero jako zasoby

Parametry od IT

MTPD i RTO ustala właściciel procesu, IT ocenia wykonalność

Wszystko jest krytyczne

Bez różnicowania klas nie ma priorytetów i budżetu

Pominięcie dostawców

Usługi zewnętrzne bez RTO i RPO w umowie

RTO ≥ MTPD

Brak zapasu czasu na decyzje i niepewność

Jednorazowy dokument

Brak przeglądów po zmianach (8.2.1 b)

Co dalej z wynikami BIA



Wyniki BIA

priorytety, MTPD, RTO, RPO, MBCO, zasoby



Strategie (8.3)

redundancja, ośrodek zapasowy, kopie, umowy z dostawcami



Plany (8.4)

BCP, plany awaryjne, DRP, komunikacja kryzysowa



Ćwiczenia (8.5)

testy odtworzenia, ćwiczenia sztabowe



Wyniki testów i każda istotna zmiana w organizacji wracają do przeglądu BIA – cykl się zamyka.

CZĘŚĆ 5



Laboratorium: przeprowadzamy BIA

Praca w zespołach na studium przypadku

Zadanie laboratoryjne

1 Kontekst

Opisz organizację, jej usługi i strony zainteresowane

2 Kryteria

Przyjmij kategorie i skalę wpływu 1–4

3 Procesy

Zidentyfikuj 6–8 procesów i właścicieli

4 Ocena w czasie

Oceń wpływ: 1 h, 4 h, 8 h, 24 h, 72 h, 7 dni

5 Parametry

Wyznacz MTPD, RTO, RPO i MBCO; przypisz klasę K1–K4

6 Zależności

Wskaż zasoby, systemy i dostawców; znajdź SPOF

Rezultat: arkusz BIA + tabela procesów z klasami krytyczności + 5-minutowa prezentacja wniosków

Podsumowanie



Prawo

Ustawa o KSC wymaga planów ciągłości działania proporcjonalnych do ryzyka i skutków



Norma

ISO 22301 (8.2.2) opisuje BIA w ośmiu krokach – od kryteriów do zależności



Pojęcia

RTO < MTPD; RPO określa akceptowalną utratę danych; MBCO – poziom minimalny



Wynik

Priorytety, klasy krytyczności K1–K4, zasoby i zależności od dostawców

Pytania i dyskusja – przechodzimy do laboratorium